Information Security

Course summary — Lectures 1 to 5

The whole course on three pages: the mechanisms, the numbers, and the traps each chapter hides.

Chapter 1 — Foundations

- CIA triad (confidentiality, integrity, availability) — every control in the course maps to one of the three.
- Threat model first: who is the attacker, what can they touch, what do they want. Security without a threat model is decoration.
- Defence in depth and least privilege; perfect security does not exist, only security expensive enough to break.
- Vulnerability vs threat vs risk: risk = likelihood × impact; controls reduce one of the factors.

Chapter 2 — The web and stateful tracking

- Cookies: `Set-Cookie` name=value; attributes `Expires`, `Secure`, `HttpOnly`, `SameSite`; the cookie jar is per-browser, per-site.
- First vs third party: the **attachment rule** — a request carries the cookies of every site it goes to; a cookie is third-party when the *registrable domain* of the setter differs from the page's.
- Parties vs origins: the party is who the data flows to (registrable domain), the origin is scheme+host+port — a same-site script on another origin still leaks.
- Cookie syncing: two trackers echo the same identifier through a redirect chain, merging their profiles.
- Respawning: deleted state rebuilt from a second store (Flash LSO, ETag cache); demonstrated by clearing cookies and still being recognised.
- The tracking pipeline ends in RTB: a bid request carries the user identifier, bought and sold before the page renders.

Chapter 3 — Stateless tracking and browser defences

- Fingerprinting: no storage at all. Features (user agent, fonts, canvas, plugins, screen, headers) are hashed into an identifier; the pipeline is measure → combine → hash → track.
- Stability vs entropy: a good feature is stable (same value per machine) and discriminative (spread over machines); the entropy of the bundle bounds how many users it separates (2^H).
- Defences: standardise or randomise. Firefox RFP returns one value to everyone; Brave farbling adds per-site noise to canvas; blocklists cut the measuring endpoints.
- Signals vs laws: DNT/GPC are requests, not enforcement; opt-out lists work only where trackers honour them.

Chapter 4 — Symmetric cryptography

- Vigenère and the group attack: same keystream letters, same ciphertext shift ⇒ columns of an anagram attack; key length by Kasiski or index of coincidence.
- One-time pad: perfect secrecy — ciphertext independent of plaintext — but the key must be as long as the message and used once.
- Feistel network: split, round $L_i = R_{i-1},\ R_i = L_{i-1} \oplus F(R_{i-1}, k_i)$; any round function, decryption runs the rounds backwards.
- DES: 16 Feistel rounds, 64-bit block, 56-bit key (8 parity bits); the 2^{56} brute force and the meet-in-the-middle that kills 2DES (2^{112} does not happen).
- AES: 128-bit block; the state goes SubBytes (S-box), ShiftRows, MixColumns, AddRoundKey; keys of 128/192/256 bits.
- Modes: ECB leaks equality (penguin picture); CBC chains with an unpredictable IV; CTR turns the cipher into a stream with a nonce — never reuse it.
- Diffie–Hellman: $A = g^a$, $B = g^b$, shared g^{ab} — key agreement over a public channel; MITM without authentication is the standing trap.

Chapter 5 — Public key, integrity and trust

- RSA: pick p, q, $n = pq$, $\varphi = (p-1)(q-1)$, $ed \equiv 1 \pmod{\varphi}$; encrypt $c = m^e$, decrypt $m = c^d$; sign by decrypting, verify by encrypting. Security rests on factoring n.
- Hybrid encryption: RSA carries a session key, AES carries the data — public key for setup, symmetric for speed.
- Hashes: compression, pre-image and second pre-image resistance, collision resistance; birthday bound — collisions appear around $2^{n/2}$, so a 128-bit hash has 64-bit collision security.
- Passwords: store salted slow hashes (bcrypt/argon2); salt kills rainbow tables, slowness kills guessing; never store the password itself.
- MAC vs signature: MAC is symmetric — only the key holders can verify; a signature is public — anyone verifies, only the key signs; non-repudiation is the difference.
- Certificates and PKI: the certificate binds a key to a name, signed by a CA; the chain of trust ends at a root the browser already believes.
- Steganography hides the existence of the message; crypto only hides its meaning.

The numbers that get asked

DES key 2^{56}, block 64 bits • AES rounds 10/12/14, block 128 bits • birthday $2^{n/2}$
DH: public g^a, g^b, shared g^{ab} • RSA: $ed \equiv 1 \bmod (p-1)(q-1)$ • cookie: registrable domain decides the party
Attachment rule: a request carries the cookies of every site it is sent to; third-party $\iff$ setter's registrable domain $\neq$ page's.

What the exam asks

Read a `Set-Cookie` line and name the party; follow a cookie-sync or respawning table; say what each AES round does and why ECB fails; compute a birthday-bound or brute-force size; tell MAC from signature in a scenario; and justify every box — the grader wants the rule, not the guess.